

صَقْر

SAQR — Security Automated Quick Response

منصة ذكية للاستجابة الآلية للحوادث الأمنية

بمركز عمليات مصغّر (Mini-SOC) ونموذج لغة محلي (Local LLM)

مشروع تخرج — الأمن السيبراني + الذكاء الاصطناعي + هندسة البرمجيات

الفكرة في سطر واحد

منصة تعمل داخل بيئة معملية معزولة، ترصد ثلاثة أنواع من الهجمات (فدية، تصيد إلكتروني، إغراق خدمات DDoS)، **تعزل الجهاز المصاب خلال ثوانٍ مع حفظ الأدلة الجنائية**، ثم يأتي نموذج ذكاء اصطناعي محلي ليحلل الحادثة، يشرحها بالعربية، ويكتب تقرير الاستجابة تلقائياً — كل ذلك عبر لوحة تحكم SOC كاملة.

المشكلة التي نحلها

- المؤسسات الليبية (بنوك، مستشفيات، جهات حكومية) بلا مركز عمليات أمنية SOC ولا قدرة استجابة للحوادث IR.
- الهجوم ينتشر أفقياً داخل الشبكة قبل أن يُكتشف، وتُفقد الأدلة الجنائية، ولا توجد تقارير عربية رسمية للحوادث.
- الحلول التجارية (SIEM/SOAR) مكلفة وسحابية ولا تدعم العربية ولا سياقنا المحلي.

ما الذي يجعل المشروع مختلفاً

🤖 ذكاء اصطناعي حقيقي

نموذج لغة محلي (لا سحابة) يفرز التنبيهات، يحلل الحوادث، ويكتب التقارير بالعربية.

⚡ استجابة آلية فورية

عزل الجهاز المصاب خلال ثوانٍ — مع لقطة ذاكرة للأدلة **قبل** إيقاف العملية.

LY مصمم للسياق المحلي

عربي بالكامل، يعمل بلا إنترنت، بميزانية صفرية (كل الأدوات مفتوحة المصدر).

القاعدة المعمارية الذهبية

قواعد حتمية للسرعة + نموذج لغة للذكاء

قرار العزل الحرج يتخذه **محرك قواعد سلوك حتمي (Deterministic)** خلال 3–4 ثوانٍ — لأنه سريع وقابل للتنبؤ. نموذج اللغة (LLM) لا يتخذ قرارات أمنية حرجة، بل يعمل **بعد الاحتواء**: يفسّر ما حدث، يربطه بإطار MITRE ATT&CK، يرتب التنبيهات حسب الخطورة، يجيب أسئلة المحلل، ويولّد التقارير العربية. هذه المعمارية الهجينة هي أساس تميز المشروع.

معمارية المنصة — خمس طبقات

1. **محرك الهجمات (Attack Engine):** سيناريوهات هجوم جاهزة تُشغَّل بنقرة زر داخل المختبر — لإعادة التجربة، وللعرض أمام اللجنة، ولتوليد بيانات الاختبار.

2. **طبقة الرصد (Detection):** Wazuh لسجلات الأجهزة + Sysmon لسلوك العمليات والملفات + Suricata لتحليل حركة الشبكة + قواعد Sigma مخصصة.

3. **محرك القرار (Decision Engine):** يستقبل التنبيهات ويطابقها مع بصمات السلوك (مثال بصمة الفدية: إعادة تسمية جماعية + حذف Shadow Copies) ويتخذ قرار الاحتواء.

4. **طبقة الاستجابة (SOAR):** لقطة ذاكرة قبل العزل، عزل شبكي عبر pfSense API، حظر عناوين IP، إبطال الجلسات، تنبيهات Telegram، وتنظيم الأدلة مع تجزئات SHA-256.

5. **طبقة الذكاء والعرض:** Ollama + نموذج Qwen2.5 محلي (ممتاز بالعربية) للتحليل والتقارير، + لوحة تحكم React بالعربية تُظهر الشبكة الحية وطابور التنبيهات وعداد الاحتواء.

أدوات المشروع

الطبقة	التقنية
بيئة المختبر	Proxmox أو VMware Workstation + أجهزة Windows 10/11 + Kali Linux (شبكة افتراضية معزولة بالكامل)
الرصد	Wazuh + Sysmon + Suricata + Sigma Rules
الاستجابة	pfSense/OPNsense API + PowerShell + Python
الذكاء الاصطناعي	Ollama + Qwen2.5 (محلي بالكامل) + RAG على Playbooks الاستجابة
المنصة	FastAPI + PostgreSQL + React + Docker

السيناريوهات الثلاثة

🔒 السيناريو الأول — الفدية (نجمة العرض)

محاكي فدية مكتوب داخلياً (**ليس برمجية خبيثة حقيقية**) يشفّر مجلد "عسل" داخل آلة افتراضية فقط، ويحاكي سلوك الفدية الحقيقي.

1. الرصد خلال ثوانٍ: بصمة السلوك (مئات عمليات إعادة التسمية + محاولة حذف نسخ النظام + نشاط تشفير مكثف).
2. **قبل** إيقاف العملية: التقاط لقطة ذاكرة (Memory Snapshot) — الأدلة الجنائية لا تُضحَّى بسرعة الاستجابة.
3. العزل الشبكي الفوري للجهاز — الهجوم لا ينتشر عبر SMB لبقية الشبكة.
4. LLM يحلل خلال ثوانٍ: يفسّر السلوك، يرسمه على خريطة MITRE ATT&CK، ويكتب تقرير الحادثة بالعربية.
5. عداد حي على الشاشة: **"تم الاحتواء خلال 3.8 ثانية"**.

🎣 السيناريو الثاني — التصيد الإلكتروني

حملة تصيد داخل المختبر بأداة GoPhish تستهدف صناديق بريد الأجهزة الافتراضية، مع صفحة دخول مزيفة.

1. الرصد من ثلاث طبقات: بوابة البريد (خصائص الرسالة) + امتداد المتصفح (نطاق شبيه بـ look-alike) + Suricata (اتصال بنطاق ضار).
2. الاستجابة الآلية: حظر النطاق على مستوى جدار الحماية + إبطال جلسات المستخدم المصاب + وضع جهازه تحت مراقبة مشددة.
3. LLM يكتب ملخصاً عربياً: من نقر؟ ماذا كُشِف؟ ماذا حُجب؟ + لوحة مؤشرات الوعي (نسبة الوقوع في الفخ).

🌊 السيناريو الثالث — إغراق الخدمات DDoS

هجوم Flood من عدة أجهزة افتراضية على خادم ويب تجريبي داخل المختبر.

1. رصد القفزة الشاذة في حركة المرور.
2. **قيمة الذكاء الاصطناعي هنا الحقيقية:** تمييز الهجوم الموزع عن ذروة الاستخدام الطبيعية (خفض الإنذارات الكاذبة).
3. الاستجابة الآلية: قواعد Rate-limiting وحظر عناوين IP المهاجمة عبر pfSense API — والخادم يبقى يعمل.

ميزات المشروع المميزة

- **وضع Red/Blue:** نفس الهجوم يُشغَّل مرتين — بمنصة وبدونها — والمقارنة معروضة بالأرقام: "الملفات المشفرة: 2,400 ← 0". نتائج مقاسة لا ادعاءات.
- **بوت Telegram:** إشعارات فورية للإدارة + أمر /status يرد بوضع الشبكة الحالي.
- **إثراء معلومات التهديدات:** فحص سمعة IP تلقائياً عند كل تنبيه.
- **كشف الحركة الجانبية:** رصد محاولات الانتشار عبر SMB ← عزل شبكي شامل (وضع الطوارئ).
- **يعمل بلا إنترنت:** كل شيء محلي (النموذج، البيانات، القرارات) — نقطة بيع حقيقية للجهات التي لا تسمح بخروج بياناتها.
- **خريطة MITRE ATT&CK حية:** كل حادثة تُربط تلقائياً بتقنيات الهجوم المعيارية.

مقاييس نجاح المشروع

≥ 5 ث	≥ 10 ث	0	> 10%
زمن كشف الفدية (MTTD)	زمن الاحتواء الكامل (MTTC)	أجهزة يصلها الانتشار	نسبة الإنذارات الكاذبة

في السيمستر الثاني يُقاس كل مقياس بـ 20 تشغيلاً تجريبياً لكل سيناريو — هذه الأرقام هي أساس فصل التقييم والورقة البحثية.

قواعد السلامة والأمان (ملزمة للجميع)

⚠️ اقرأها قبل أي عمل تقني

- كل الهجمات داخل بيئة افتراضية معزولة بالكامل — لا اتصال بشبكة الجامعة أو المنزل أو أي نظام خارجي.
- محاكي الفدية يُكتب داخلياً ويستهدف مجلداً واحداً محدداً فقط — ولا يُنشر كوده النشط.
- لا استخدام لأي برمجية خبيثة حقيقية من الإنترنت — كل أدوات الهجوم محاكيات داخلية.
- المشروع دفاعي بالكامل: الهجمات وسيلة اختبار للدفاع فقط.

ماذا نسلّم في كل سيمستر؟

مشروع التخرج 1 (Demo)

المعمل يعمل + سيناريو الفدية كامل الحلقة (هجوم ← كشف ← لقطة ذاكرة ← عزل ← تقرير LLM عربي) + لوحة SOC + تقرير السيمستر.

مشروع التخرج 2 (المنتج)

سيناريو التصيد وDDoS + طبقة SOAR كاملة + وضع Red/Blue + فصل التقييم المقاس + الورقة البحثية + العرض النهائي.